

Future Interns
Cyber Security Task 1 (2026)

Vulnerability Assessment Report

Name: Shifa Tahreem

Internship Name: CyberSecurity Internship

CIN: FIT/JUN26/CS9072

Target Website: <https://demo.owasp-juice.shop>

Date: June 2026

Executive Summary

A read-only vulnerability assessment was conducted on the target web application using passive security testing techniques.

The assessment focused on publicly accessible services, HTTP security headers, and basic web application configuration analysis.

Several low and medium-risk findings were identified. Recommendations have been provided to improve the security posture of the website and reduce exposure to common web threats.

Scope and Methodology

Target Website: <https://demo.owasp-juice.shop>

Assessment Scope:

- Public-facing resources only
- Passive security testing
- Security header review
- Network service enumeration

Tools Used:

- Nmap
- OWASP ZAP
- Browser Developer Tools
- SecurityHeaders.com

Restrictions:

- No exploitation performed
- No login bypass attempts
- No denial-of-service testing
- No brute-force attacks

Assessment Evidence

```
Microsoft Windows [Version 10.0.26200.8457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\shifa>nmap demo.owasp-juice.shop
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-06 15:25 +0530
Nmap scan report for demo.owasp-juice.shop (81.169.145.156)
Host is up (0.20s latency).
Other addresses for demo.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
443/tcp   open  https
445/tcp   filtered microsoft-ds
1022/tcp  filtered exp2
1023/tcp  filtered netvenuechat
1026/tcp  filtered LSA-or-nterm
8080/tcp  open  http-proxy
9898/tcp  filtered monkeycom

Nmap done: 1 IP address (1 host up) scanned in 30.42 seconds

C:\Users\shifa>
```

Figure 1: Basic Nmap Scan

```
1026/tcp filtered LSA-or-nterm
8080/tcp open http-proxy
9898/tcp filtered monkeycom

Nmap done: 1 IP address (1 host up) scanned in 30.42 seconds

C:\Users\shifa>nmap -sV demo.owasp-juice.shop
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-06 15:26 +0530
Nmap scan report for demo.owasp-juice.shop (81.169.145.156)
Host is up (0.19s latency).
Other addresses for demo.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ftpd.bin round-robin file server 3.4.0r16
80/tcp    open  http-proxy F5 BIG-IP load balancer http proxy
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
443/tcp   open  ssl/http Apache httpd 2.4.67 ((Unix))
445/tcp   filtered microsoft-ds
1022/tcp  filtered exp2
1023/tcp  filtered netvenuechat
1026/tcp  filtered LSA-or-nterm
8080/tcp  open  http-proxy F5 BIG-IP load balancer http proxy
9898/tcp  filtered monkeycom
Service Info: Device: load balancer

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.31 seconds

C:\Users\shifa>
C:\Users\shifa>
C:\Users\shifa>
```

Figure 2: Nmap Service Detection Scan

Figure 1 & Figure 2: Nmap Analysis

A basic Nmap scan and service detection scan (-sV) were performed to identify publicly accessible services on the target website. The assessment revealed multiple open ports, including FTP, HTTP, HTTPS, and proxy-related services. These scans help evaluate the exposed attack surface and identify services that should be reviewed from a security perspective.

Security Headers Assessment

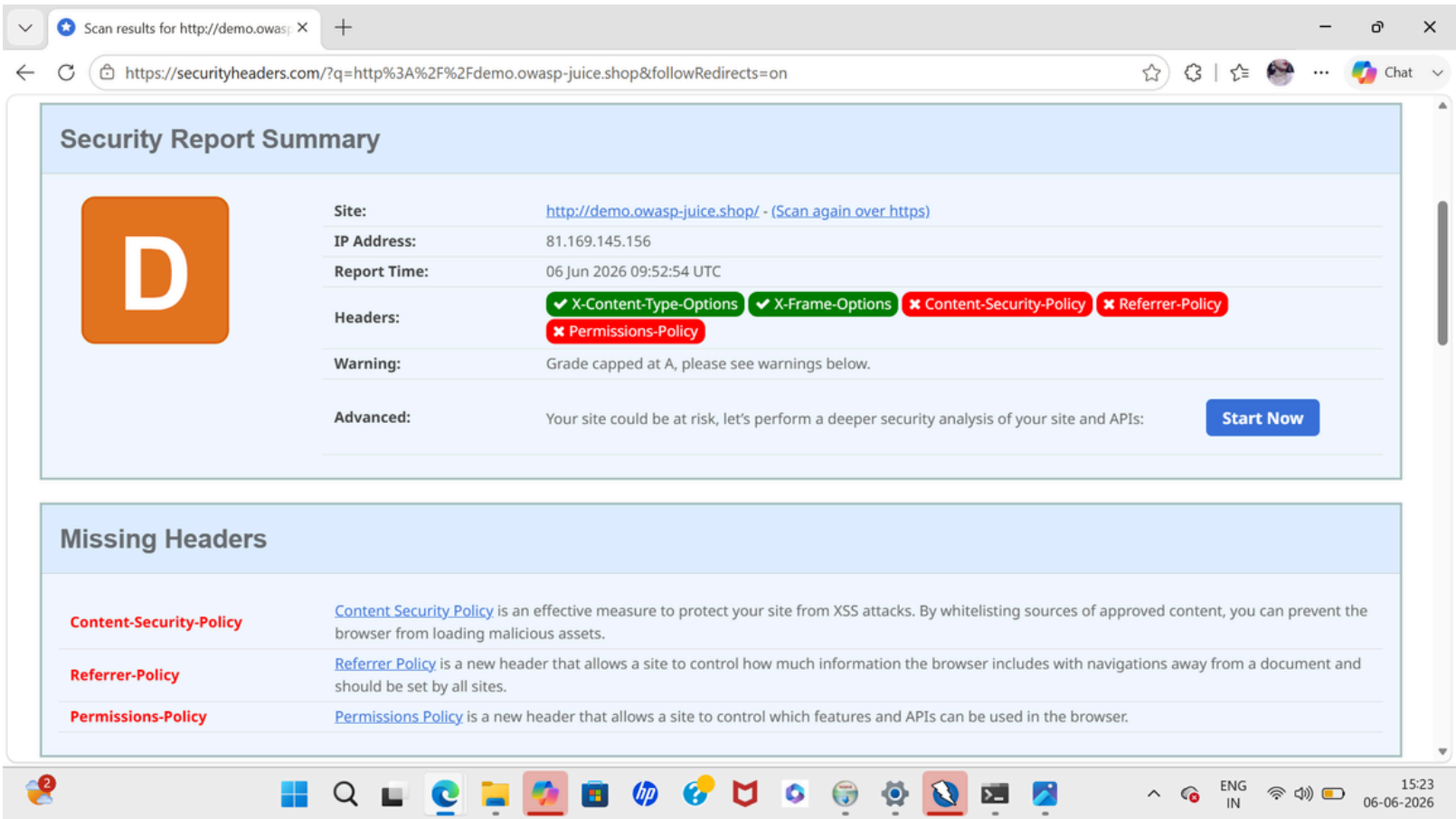


Figure 3: HTTP Security Headers Scan

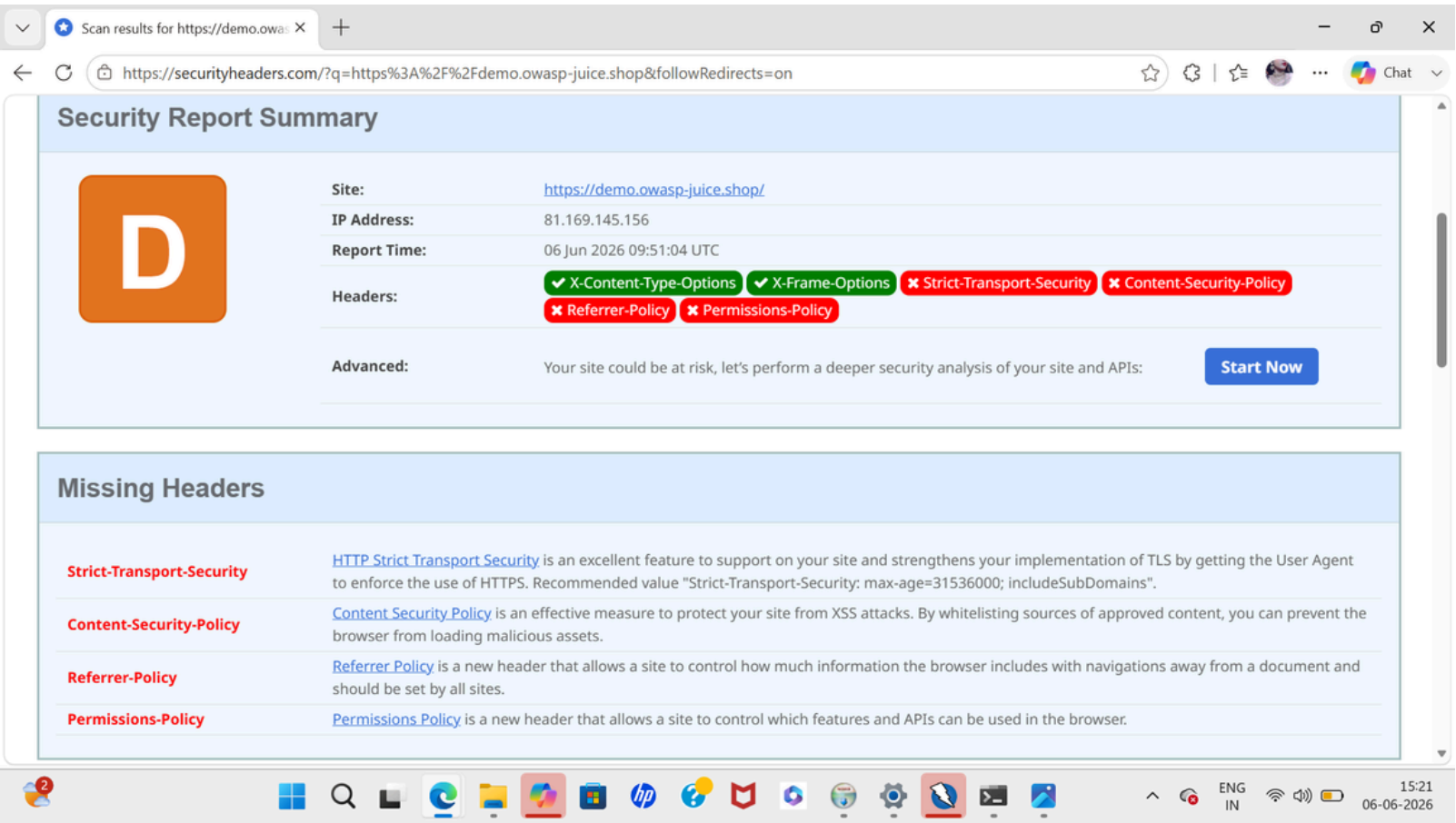


Figure 4: HTTPS Security Headers Scan

A security header assessment was performed on both the HTTP and HTTPS versions of the target website. The analysis identified missing security headers, including Content-Security-Policy, Referrer-Policy, and Permissions-Policy. The HTTP version was also accessible without automatic redirection to HTTPS.

Observation: Missing security headers may reduce protection against common web-based attacks, while allowing HTTP access can expose user communications to unnecessary security risks. Implementing the recommended headers and enforcing HTTPS would strengthen the overall security posture of the website.

OWASP ZAP Passive Assessment

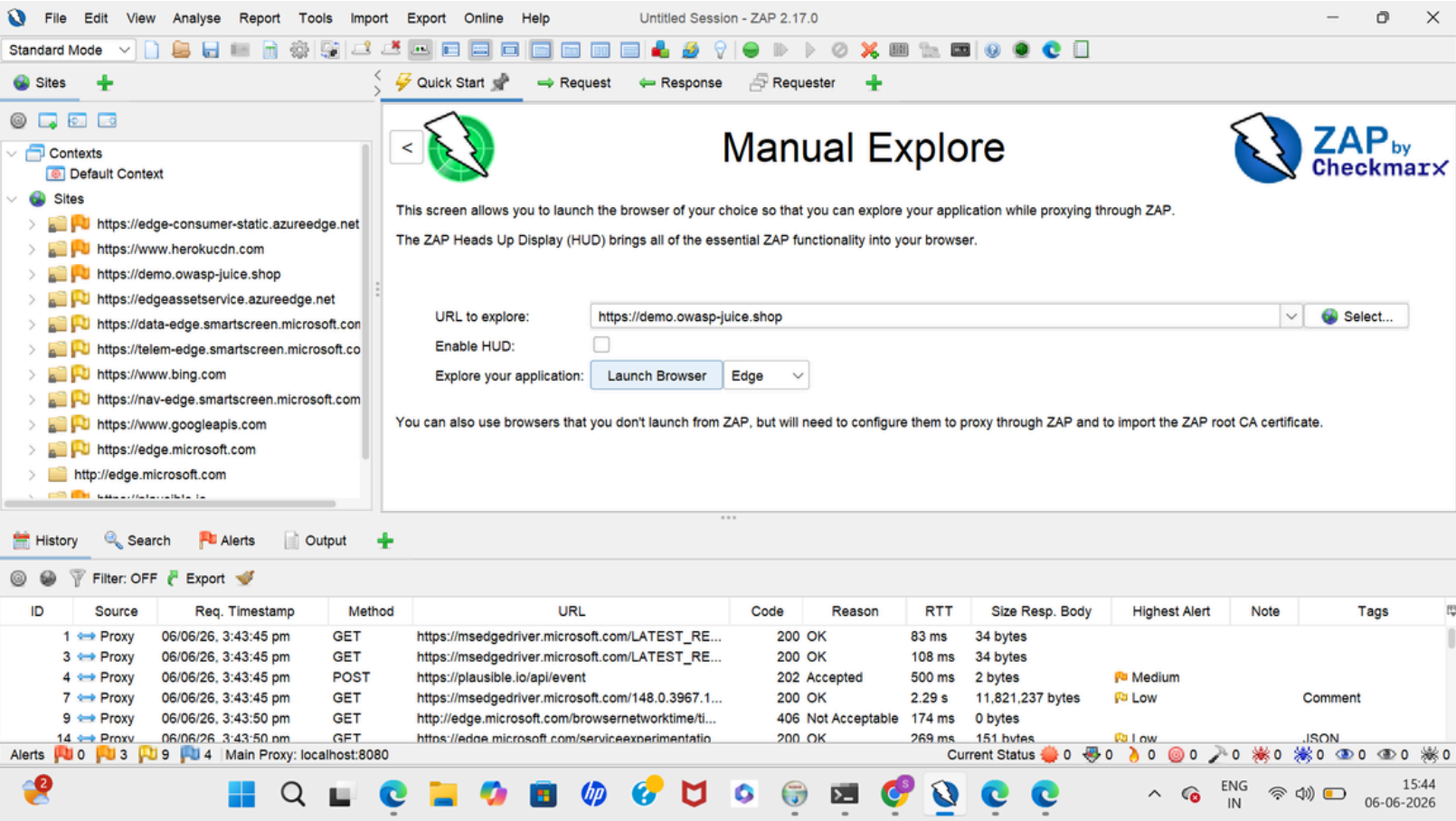


Figure 5: OWASP ZAP Interface

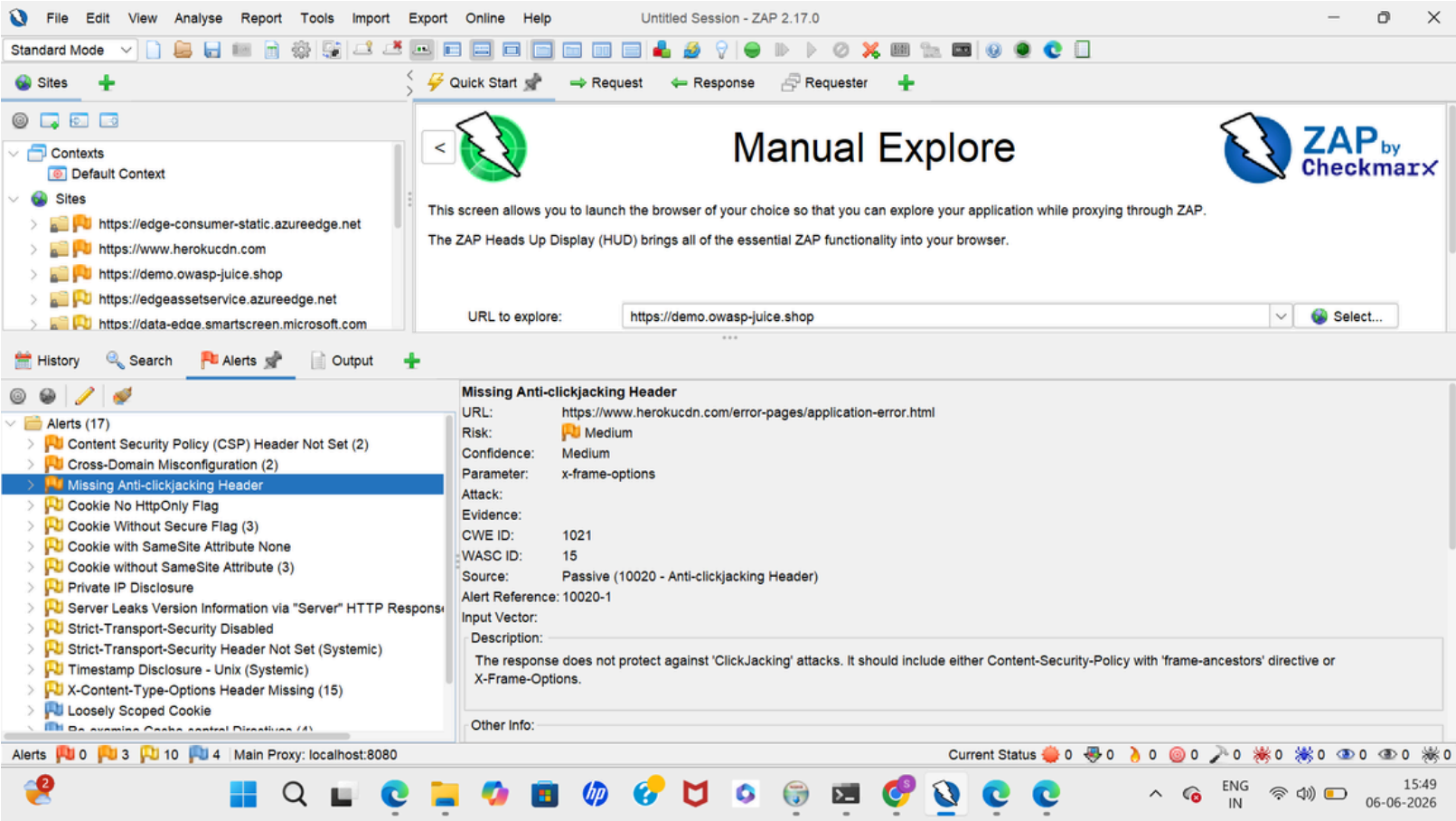


Figure 6: OWASP ZAP Alerts

OWASP ZAP was used to perform a passive security assessment of the target website. The tool was utilized to observe application traffic, inspect requests and responses, and identify potential security issues without actively exploiting the application.

Observation: The passive assessment helped identify security-related observations and provided additional visibility into the application's structure and behavior. Passive testing ensures that the assessment remains ethical and non-intrusive while still revealing potential areas for security improvement.

Findings Summary

A total of 5 findings were identified: 2 Medium Risk and 3 Low Risk.

ID	Finding	Risk
F-01	Missing Content Security Policy	Medium
F-02	Missing Referrer Policy	Low
F-03	Missing Permissions Policy	Low
F-04	Website Accessible Over HTTP	Medium
F-05	Publicly Accessible Services	Low

Detailed Findings

F-01: Missing Content Security Policy (CSP)

Risk Level: Medium

Issue: The website does not implement a Content Security Policy header.

Business Impact: This reduces protection against malicious script execution and cross-site scripting attacks.

Recommended Fix: Implement a Content-Security-Policy header to restrict trusted content sources.

F-02: Missing Referrer Policy

Risk Level: Low

Issue: The website does not define a Referrer Policy.

Business Impact: URL information may be exposed when users navigate to external websites.

Recommended Fix: Configure an appropriate Referrer-Policy header such as strict-origin-when-cross-origin.

F-03: Missing Permissions Policy

Risk Level: Low

Issue: The website does not define a Permissions Policy.

Business Impact: Browser features are not explicitly restricted.

Recommended Fix: Implement a Permissions-Policy header.

F-04: Website Accessible Over HTTP

Risk Level: Medium

Issue: The website can be accessed using HTTP.

Business Impact: Unencrypted communication may increase exposure to interception risks.

Recommended Fix: Redirect all HTTP traffic to HTTPS and enable HSTS.

F-05: Publicly Accessible Services

Risk Level: Low

Issue: Network scanning identified multiple publicly accessible services.

Business Impact: Additional exposed services increase the attack surface.

Recommended Fix: Review exposed services and disable any unnecessary services.

Conclusion

The assessment identified several security configuration weaknesses, primarily related to missing security headers and exposed network services.

No active exploitation was performed during testing. The findings were gathered through ethical, read-only assessment techniques.

Implementing the recommended remediation steps will improve the overall security posture of the website and reduce exposure to common web application threats.

"No critical vulnerabilities were identified during the passive assessment."